

IT4015 – Nhập môn An toàn thông tin

HUST

ĐẠI HỌC BÁCH KHOA HÀ NỘI
HANOI UNIVERSITY OF SCIENCE AND TECHNOLOGY

ONE LOVE. ONE FUTURE.



ĐẠI HỌC
BÁCH KHOA HÀ NỘI
HANOI UNIVERSITY
OF SCIENCE AND TECHNOLOGY

CÁC CƠ CHẾ PHÁT HIỆN XÂM NHẬP MẠNG

Báo cáo bài tập lớn - IT4015 Nhập môn An toàn thông tin

Người thực hiện:

Nguyễn Đình Tuấn Minh - 20230048

Vũ Đức Tâm - 20230064

Nguyễn Gia Khánh - 202416803

Nguyễn Đăng Cao Tuấn - 202400119

Trường Công nghệ Thông tin và Truyền thông - Đại học Bách khoa Hà Nội

Giảng viên hướng dẫn: PGS. TS. Nguyễn Linh Giang

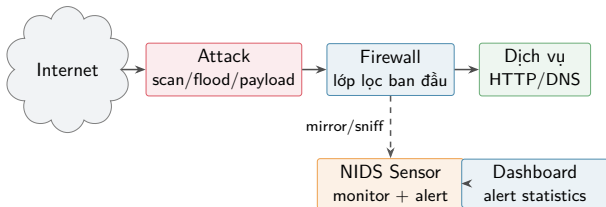
ONE LOVE. ONE FUTURE.

1. Bài toán và mục tiêu
2. Kiến trúc hệ thống
3. Attack and Detection Mechanisms
4. IDS Design Simulation
5. Demo và đánh giá
6. Kết luận

Vì sao cần NIDS?

Bối cảnh

- ▶ Firewall chưa đủ để hiểu toàn bộ traffic behavior.
- ▶ Attack traffic có thể đi qua HTTP, DNS hoặc internal traffic.
- ▶ Cần alert sớm để điều tra và phản ứng.



NIDS hoạt động thụ động: đọc traffic, phân tích và sinh alert; không chặn trực tiếp như IPS.

Project objectives

- ▶ Xây dựng NIDS nhỏ gọn bằng Python.
- ▶ Minh họa hai detection layers: behavior-based và signature-based.

PCAP / Live

data source

5 rules

behavior detection

3 rules

HTTP signature demo

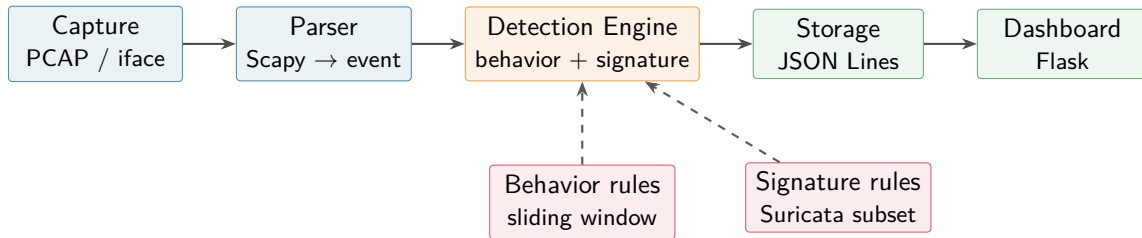
Đã thực hiện

- ▶ Packet capture bằng Scapy.
- ▶ Chuẩn hóa thành PacketEvent.
- ▶ Detect port scan, ICMP flood, SYN flood, DNS đáng ngờ, DNS tunneling.
- ▶ Match Suricata-style rule subset cho HTTP/DNS/payload.
- ▶ Lưu JSONL và trực quan hóa bằng Flask.

Giới hạn chủ động đặt ra

- ▶ Không thay thế Suricata, Zeek hoặc IDS production.
- ▶ Chưa giải mã TLS/HTTPS.
- ▶ Chưa tái tạo TCP stream đầy đủ.
- ▶ Detection threshold dùng cấu hình tĩnh để dễ trình diễn.

Pipeline xử lý của hệ thống



Design idea

The proposed NIDS follows a CIDEF-like IDS pipeline architecture and implements a lightweight Suricata/Snort-style detection model, combining behavior-based detection with signature-based rule matching.

Design statement

The proposed NIDS follows a CIDEF-like IDS pipeline architecture and implements a lightweight Suricata/Snort-style detection model, combining behavior-based detection with signature-based rule matching.

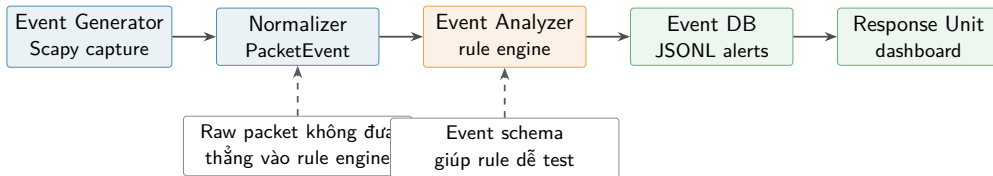
CIDEF-like pipeline

- ▶ Tách vai trò capture, analysis, storage và visualization.
- ▶ Mỗi module nhận một data format rõ ràng.
- ▶ Dễ thay thế PCAP/live traffic source hoặc dashboard.

Suricata/Snort-style model

- ▶ Rule có header và option.
- ▶ So khớp payload, HTTP field, DNS query.
- ▶ Kết hợp với rule behavior dùng time window.

CIDF-like Pipeline Mapping



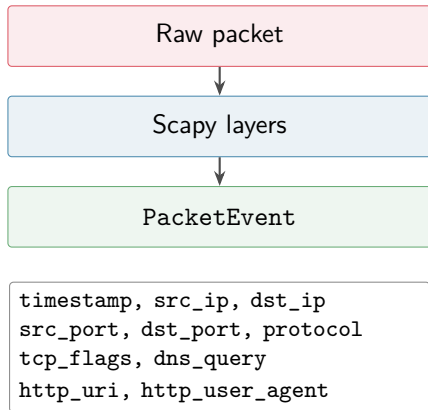
Packet Normalization thành PacketEvent

Vấn đề

- ▶ Raw packet phụ thuộc từng giao thức và thư viện Scapy.
- ▶ Rule engine cần cùng một schema để đánh giá TCP, ICMP, DNS, HTTP.
- ▶ Nếu xử lý trực tiếp payload thô, rule sẽ khó viết và khó kiểm thử.

Cách làm

- ▶ Parser rút ra metadata chung: IP, port, protocol, length, TCP flags.
- ▶ Parser bổ sung trường chuyên biệt: DNS query, HTTP method, URI, Host, User-Agent, payload text.

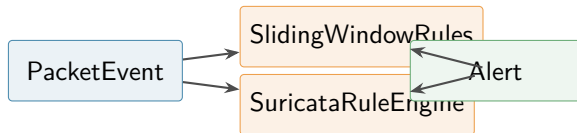


1. Behavior-based detection

- ▶ Theo dõi event sequence trong time window.
- ▶ Phù hợp với scan, flood, tunneling và frequency anomaly.
- ▶ Không cần biết trước payload chính xác.

2. Signature-based matching

- ▶ So khớp rule với header, buffer HTTP/DNS/payload.
- ▶ Phù hợp với SQL Injection, công cụ tự động, chuỗi độc hại đã biết.
- ▶ Alert dễ giải thích bằng evidence.



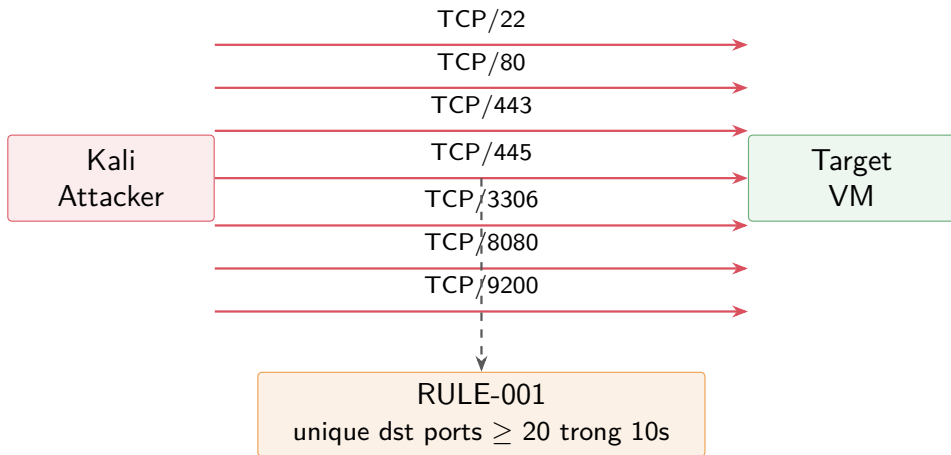
Attack mechanism

- ▶ Attacker gửi probe TCP tới nhiều cổng của cùng mục tiêu.
- ▶ Mục tiêu là identify open services: SSH, HTTP, SMB, database.
- ▶ Đây thường là bước tiền khai thác trước khi chọn lỗ hổng cụ thể.

Detection condition trong đồ án

- ▶ Một source chạm **20 unique TCP destination ports trong 10 giây**.
- ▶ Chỉ đếm các flag probe: SYN, FIN, NULL, XMAS, ACK.
- ▶ Không đếm response packets như RST hoặc SYN-ACK để giảm false positive.

Port Scan: probe flow



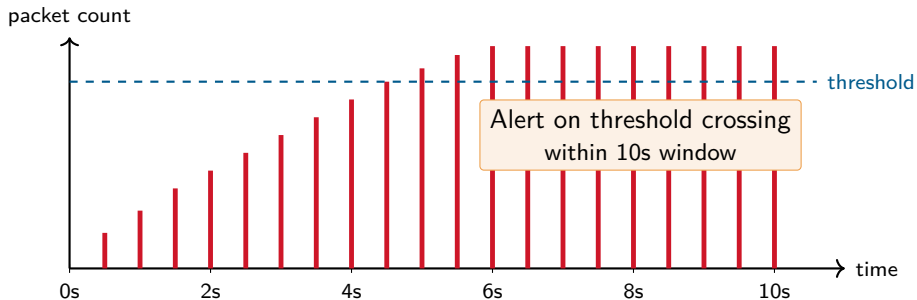
ICMP Ping Flood

- ▶ Gửi nhiều Echo Request để tiêu tốn băng thông hoặc CPU xử lý.
- ▶ Rule chỉ đếm request-side: type 8, 13, 17.
- ▶ Demo threshold: **100 packets / 10 seconds**.

TCP SYN Flood

- ▶ Gửi nhiều SYN để tạo trạng thái kết nối chưa hoàn tất.
- ▶ Rule đếm packet có TCP flag đúng bằng S.
- ▶ Demo threshold: **100 SYN / 10 seconds**.

Flood: threshold crossing over time



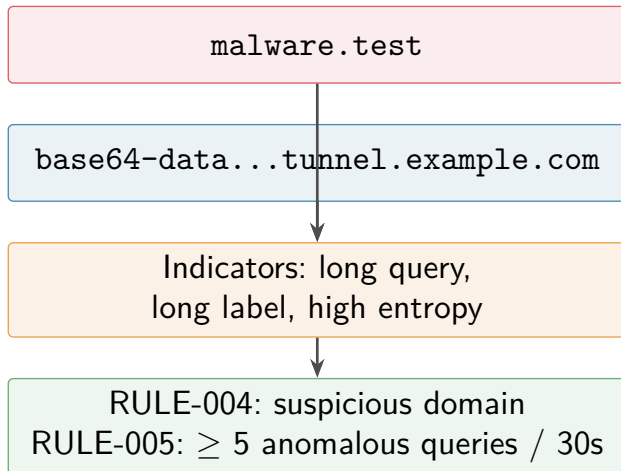
Attack mechanism

- ▶ DNS thường được phép đi qua firewall nên có thể bị lợi dụng làm kênh phụ.
- ▶ Attacker có thể query malicious domain hoặc nhúng data vào DNS label.
- ▶ Encoded/base64 data thường tạo long label, khó đọc và entropy cao.

Shannon entropy dùng để đánh giá label

$$H(X) = - \sum_i p(x_i) \log_2 p(x_i)$$

- ▶ Label đủ dài và có entropy ≥ 3.8 được xem là chỉ báo tunneling.
- ▶ RULE-005 tạo alert khi có ít nhất 5 anomalous queries trong 30 giây.



Demo rules

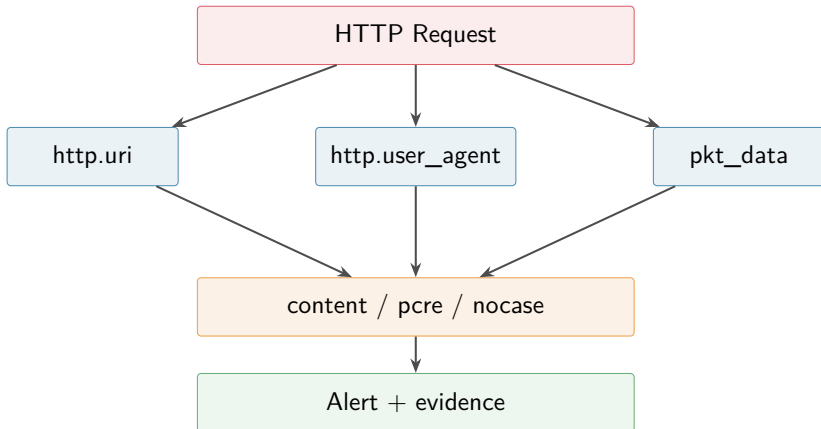
- ▶ SQL Injection trong HTTP URI.
- ▶ User-Agent chứa sqlmap.
- ▶ SQL Injection trong body POST hoặc payload thô.

Rule example

Suricata-style

```
alert http any any -> any 80
(msg:"sqlmap Scanner User-Agent Detected";
http.user_agent; content:"sqlmap"; nocase;
classtype:attempted-recon; priority:2; sid:1000002; rev:1;)
```

HTTP Signature: sticky buffer diagram



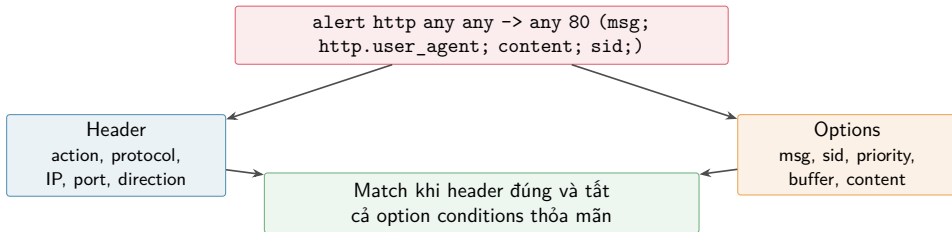
Không xây dựng IDS production

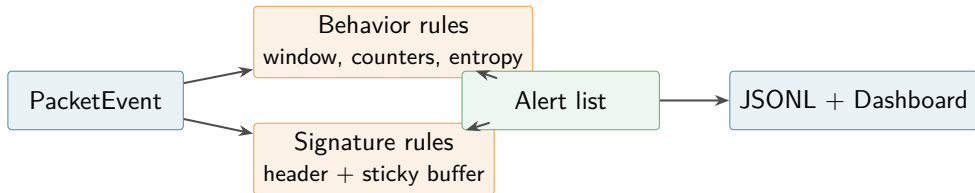
- ▶ Mục tiêu là simulate các core functional blocks của một NIDS.
- ▶ Ưu tiên readability, demoability và testability hơn high performance.
- ▶ Mỗi alert cần có rule ID, description và evidence để giải thích được.

Hai detection layers được simulate

- ▶ Behavior-based detection: detect anomaly theo frequency, time window và entropy.
- ▶ Signature-based matching: simulate cách Snort/Suricata dùng rule để match header, buffer và content.

Snort/Suricata-style Rule Model





Ý nghĩa

Behavior rules bắt anomaly patterns theo time series; signature rules bắt known payload hoặc application fields. Hai nhánh cùng sinh ra một Alert format.

Main alert fields

- ▶ rule_id: rule identifier.
- ▶ attack_type: attack type.
- ▶ severity: mức độ nghiêm trọng.
- ▶ source_ip, destination_ip.
- ▶ description: short description.
- ▶ evidence: explanatory data.

Evidence example

```
{  
  "unique_ports": [22, 80, 443],  
  "count": 20  
}
```

Vai trò

Evidence giúp người xem dashboard hiểu vì sao rule được kích hoạt, thay vì chỉ thấy một alert label.

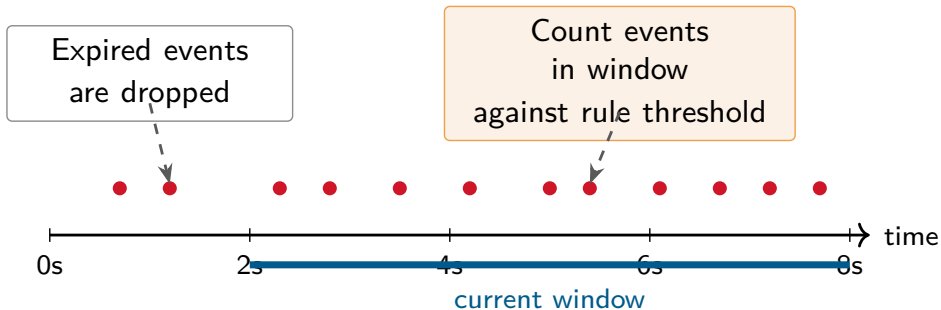
Idea

- ▶ Mỗi source có một queue chứa recent events.
- ▶ Khi event mới đến, hệ thống drop expired data.
- ▶ Nếu count hoặc feature vượt threshold thì tạo alert.

Benefits

- ▶ Dễ giải thích bằng evidence trong alert.
- ▶ Memory cost giới hạn theo số source và time-window length.
- ▶ Phù hợp để illustrate scan, flood và DNS tunneling.

Sliding Window: timeline



Port scan

- ▶ Chỉ đếm flag probe: S, F, NULL, FPU, A.
- ▶ Không đếm RST, SYN-ACK, FIN-ACK vì thường là response packets.

ICMP flood

- ▶ Chỉ đếm request-side: Echo, Timestamp, Address Mask Request.
- ▶ Không đếm Echo Reply để tránh gây nhầm flood source cho target.

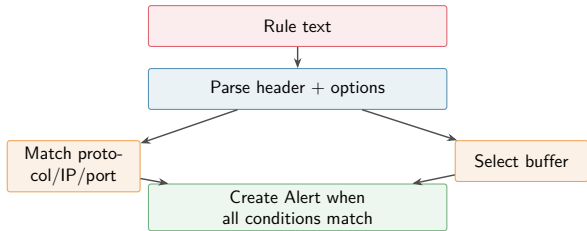
Alert cooldown

- ▶ Cùng một rule và cùng một key chỉ re-alert sau 5 giây.
- ▶ Dashboard không bị ngập bởi duplicate alerts.

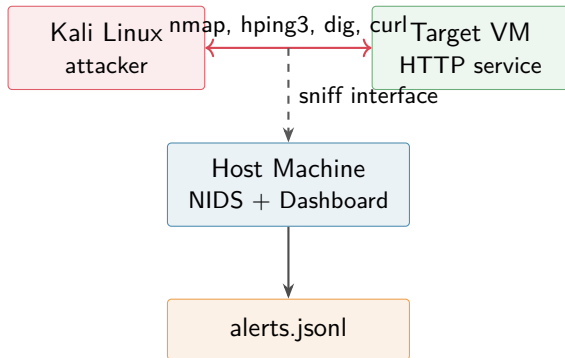


Rule components

- ▶ Header: action, protocol, IP, port, direction.
- ▶ Options: msg, sid, priority, content, pcre.
- ▶ Sticky buffers: pkt_data, raw_data, dns.query, HTTP fields.



Mô hình lab kiểm thử

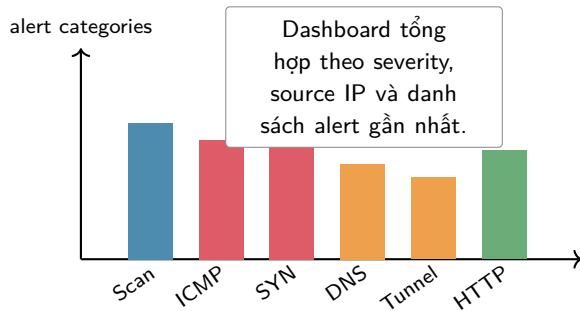


Demo objective

Chứng minh cùng một pipeline có thể detection cả anomaly theo tần suất và payload khớp signature, sau đó hiển thị thống kê alert trên dashboard.

Demo scenarios and corresponding rules

Scenario	Attack mechanism	Detection signal	Rule
Port scan	Nmap probes multiple TCP ports	≥ 20 ports / 10s	RULE-001
ICMP flood	Many Echo Requests	≥ 100 packets / 10s	RULE-002
SYN flood	Many TCP SYN packets to port 80	≥ 100 SYN / 10s	RULE-003
Suspicious DNS	Domain query in blacklist	exact/subdomain match	RULE-004
DNS tunneling	Long label, high entropy	≥ 5 queries / 30s	RULE-005
HTTP attack	URI/User-Agent/body contains malicious pattern	content match	custom.rules



Kết quả mong đợi trong lab

- ▶ Terminal NIDS prints alerts in real time.
- ▶ File JSONL append từng alert độc lập.
- ▶ Dashboard hiển thị tổng alert, severity, top source IP và alert gần nhất.

Ý nghĩa đánh giá

- ▶ Kiểm chứng đủ hai lớp detection.
- ▶ Chứng minh data đi hết pipeline từ capture tới dashboard.

Điểm đạt được

- ▶ Kiến trúc module rõ: capture, parser, engine, storage, dashboard.
- ▶ Rule behavior giải thích được bằng threshold và evidence.
- ▶ Rule signature bám theo cú pháp Suricata quen thuộc.
- ▶ Có unit test cho parser/rule engine và script demo.

Hạn chế

- ▶ Không phân tích payload trong TLS/HTTPS.
- ▶ Payload chia nhỏ qua nhiều TCP segment có thể bị bỏ sót.
- ▶ Chưa đo false positive/false negative trên dataset lớn.
- ▶ Python + Scapy phù hợp demo hơn môi trường tốc độ cao.

Kết luận

- ▶ Đề án illustrates một NIDS hoàn chỉnh ở mức học tập.
- ▶ Hai cơ chế detection bổ sung cho nhau: behavior detection anomaly, signature detection mẫu đã biết.
- ▶ Dashboard giúp biến alert thô thành thông tin quan sát được.

Hướng phát triển

- ▶ TCP stream reassembly để so khớp payload theo phiên.
- ▶ Mở rộng tương thích Suricata rule.
- ▶ Cấu hình threshold/rule qua YAML hoặc dashboard.
- ▶ Đo hiệu năng trên PCAP lớn và đánh giá false positive.
- ▶ Tích hợp webhook hoặc danh sách chặn trong lab.

THÔNG TIN ĐỒ ÁN

Đề tài: Các cơ chế detection xâm nhập mạng

Học phần: IT4015 - Nhập môn An toàn thông tin

Giảng viên hướng dẫn: PGS. TS. Nguyễn Linh Giang

Nhóm sinh viên:

Nguyễn Đình Tuấn Minh - 20230048

Vũ Đức Tâm - 20230064

Nguyễn Gia Khánh - 202416803

Nguyễn Đăng Cao Tuấn - 202400119

Xin chân thành cảm ơn thầy và các bạn đã lắng nghe!

- [1] Open Information Security Foundation, *Suricata User Guide*.
- [2] Scapy Project, *Scapy Documentation*.
- [3] Gordon Lyon, *Nmap Network Scanning*.
- [4] Nhóm sinh viên, *Báo cáo đồ án: Các cơ chế detection xâm nhập mạng*, 2026.

A decorative graphic on the left side of the slide. It features a dark blue background with a large, stylized circular pattern composed of many small red dots. The dots are arranged in concentric, slightly offset rings, creating a sense of depth and movement. The word "HUST" is centered within this pattern.

HUST

THANK YOU !

